

BRIGHTCARE HEALTH CLINIC

PHISHING INCIDENT RESPONSE PLAYBOOK

Information Security | Incident Response

Document ID	BCHC-IR-PB-001
Version	1.0
Classification	CONFIDENTIAL — Internal Use Only
Owner	Information Security Team
Applies To	All BrightCare Health Clinic Staff, Contractors & Third Parties
Review Cycle	Annual or after a significant phishing incident
Effective Date	June 2026
Prepared By	Bikash Raya — Cybersecurity Portfolio Project
Framework	NIST CSF HIPAA Security Rule 45 CFR 164.308

HIPAA Notice

BrightCare Health Clinic handles Protected Health Information (PHI). All security incidents — including phishing — must be managed in compliance with the HIPAA Security Rule (45 CFR 164.308) and HIPAA Breach Notification Rule (45 CFR 164.400).

1. Purpose & Objective

This playbook provides BrightCare Health Clinic with a standardized, step-by-step procedure for identifying, investigating, containing, and remediating phishing-related security incidents. It is designed to minimize the impact to clinic operations, protect patient Protected Health Information (PHI), and ensure compliance with HIPAA Security Rule requirements.

As a healthcare organization handling sensitive patient data including medical records, treatment histories, and billing information, BrightCare Health Clinic is a high-value target for phishing campaigns. This playbook ensures that all staff and IT personnel respond to phishing incidents consistently and effectively.

2. Scope

2.1 Incident Types Covered

- Phishing emails targeting clinic staff
- Business Email Compromise (BEC) targeting finance or administration
- Credential harvesting attacks (fake login pages)
- Malicious attachment delivery (ransomware, malware)
- Suspicious login activity resulting from phishing
- Spear-phishing targeting medical staff or executives

2.2 Systems & Platforms in Scope

- Microsoft 365 / Exchange Online (clinic email)
- Electronic Health Record (EHR) systems
- Endpoint devices (laptops, desktops, mobile devices)
- Active Directory / Azure Active Directory
- Remote access systems (VPN, Remote Desktop)
- Cloud SaaS platforms used by clinical staff

3. Trigger Conditions

This playbook is initiated when any of the following conditions occur:

- A staff member reports a suspected phishing email to the IT/Security team
- The email security gateway flags a message as malicious or suspicious
- Microsoft Defender for Office 365 generates a phishing alert
- A suspicious sign-in alert is triggered in Azure AD / Microsoft Entra ID
- Unusual mailbox activity is detected (auto-forwarding, inbox rules, bulk deletion)
- A staff member reports clicking a suspicious link or entering credentials

4. Severity Classification

All phishing incidents must be classified using the following severity levels before response actions are taken:

Severity	Description & HIPAA Implication
LOW	Phishing email delivered but no staff interaction. No PHI exposure risk. No breach notification required.
MEDIUM	Staff clicked a link but did not submit credentials. Precautionary response required. PHI exposure is unlikely.
HIGH	Credentials submitted or malicious attachment executed. PHI exposure possible. HIPAA Risk Assessment required.
CRITICAL	Confirmed account compromise or lateral movement detected. PHI breach likely. Breach Notification Rule (45 CFR 164.400) may apply.

HIPAA Requirement

Any incident classified as HIGH or CRITICAL requires a HIPAA Risk Assessment per 45 CFR 164.308(a)(1). If a breach of unsecured PHI is confirmed, notification obligations under the HIPAA Breach Notification Rule (45 CFR 164.400) must be assessed within 60 days.

5. Roles & Responsibilities

Role	Responsibility
All Staff	Report suspicious emails immediately. Do not forward, click, or delete until instructed.
IT / Help Desk	Receive initial reports. Escalate to the Security team. Support containment actions.
Information Security Team	Lead investigation. Classify severity. Execute containment and eradication steps.
Clinic Manager / Leadership	Notified for HIGH/CRITICAL incidents. Approve communication to patients if PHI is exposed.
Legal / Compliance Officer	Assess HIPAA breach notification obligations. Manage regulatory reporting.
HR Department	Involved if an incident involves insider threat or staff disciplinary action.

6. Investigation Steps

Step 1 — Initial Triage

Upon receiving a phishing report, the Security team must immediately:

- Review the reported email in full
- Analyze the sender address for spoofing or lookalike domains (e.g., brightcare-clinic.com vs brightcareclinic.com)
- Check email headers for SPF, DKIM, and DMARC authentication status
- Identify and analyze any malicious URLs or attachments using tools such as VirusTotal or Microsoft Defender
- Determine whether other staff members received the same email

Document the following:

- Email subject line
- Sender email address and display name

- Date and time received
- List of affected or exposed staff
- Any URLs or attachment names identified

Step 2 — Determine User Interaction

Contact the reporting staff member and confirm the following:

- Did they click any link in the email?
- Did they enter credentials (username/password) on any website?
- Did they download or open any attachment?
- Did they approve or dismiss an MFA prompt?
- Did they forward the email to anyone?

Classify the incident severity based on responses (see Section 4).

Step 3 — Log & Alert Review

The Security team must review the following sources:

- Azure AD / Microsoft Entra ID sign-in logs
- Risky sign-in and impossible travel alerts
- Mailbox audit logs (forwarding rules, inbox rules, sent items)
- Email message trace logs
- Microsoft Defender for Office 365 alerts

If an attachment was involved, also review:

- Endpoint Detection and Response (EDR) logs
- File hash reputation against threat intelligence feeds
- Process execution events (Sysmon Event ID 1 if Sysmon deployed)
- EHR system access logs for any unusual patient record queries

7. Containment Actions

LOW Severity — No User Interaction

- Remove the phishing email from all mailboxes (Microsoft 365 Content Search / Purge)
- Block the sender email address and domain
- Add the malicious URL to the block list
- Document and close case

MEDIUM Severity — Link Clicked, No Credentials Submitted

- Reset the staff member password as a precaution
- Revoke all active sessions in Azure AD
- Re-register MFA if the device is untrusted
- Monitor the account for 24-48 hours for suspicious activity

- Remove the phishing email from all mailboxes

HIGH Severity — Credentials Submitted

Immediate actions (within 1 hour):

- **Reset password immediately**
- **Revoke all active sessions**
- **Force MFA re-enrollment**
- **Disable account temporarily if active compromise is suspected**

Then check for:

- Newly created inbox or forwarding rules
- New OAuth app consent grants
- Suspicious logins from unknown IP addresses or locations
- Any PHI access in the EHR system during the compromise window

CRITICAL Severity — Confirmed Account Compromise

- Disable the affected account immediately
- Initiate a full account compromise investigation
- Check for lateral movement to other accounts or systems
- Review SharePoint / OneDrive for bulk downloads
- Review EHR audit logs for PHI access during compromise window
- Notify Clinic Manager and Legal/Compliance Officer
- Conduct HIPAA Risk Assessment (45 CFR 164.308(a)(1))
- Assess Breach Notification obligations (45 CFR 164.400) within 60 days

8. Eradication

- Remove all malicious inbox and forwarding rules
- Remove unauthorized OAuth application consent grants
- Clean or reimaged infected endpoints if malware was executed
- Block all identified malicious domains and IP addresses
- Patch affected systems if a vulnerability was exploited

9. Recovery

- Restore user account access after confirmation of secure credentials and MFA
- Confirm secure login from a trusted device and location
- Monitor the account for at least 7 days post-recovery
- Conduct a phishing awareness reminder for all staff
- Update EHR access credentials if PHI systems were accessed

10. Communication Plan

Audience	Trigger	Message Content
Affected Staff	All severities	Summary of incident, actions taken, next steps, do not reuse password
IT Team	Medium+	Endpoint details, systems involved, containment status
Clinic Manager	High/Critical	Business impact, PHI risk assessment status, timeline
Legal/Compliance	Critical or PHI exposure	HIPAA breach assessment required, regulatory timeline
Patients (if PHI breach)	Critical — breach confirmed	HIPAA Breach Notification within 60 days of discovery

11. Evidence Collection

The following evidence must be preserved in accordance with HIPAA documentation requirements:

- Full email headers and raw message source
- Microsoft 365 message trace logs
- Azure AD / Entra ID sign-in logs
- Endpoint logs (Windows Event Logs, Sysmon if deployed)
- File hashes of any attachments
- Screenshots of malicious URLs or login pages (before takedown)
- EHR access audit logs if PHI access is suspected

Chain of Custody

All evidence collected during a HIGH or CRITICAL incident must follow documented chain-of-custody procedures. This is required for potential HIPAA enforcement proceedings or legal action. Evidence must be stored securely and access logged.

12. Post-Incident Actions

- Document the full incident timeline within 24 hours of closure
- Conduct a lessons-learned session with the Security and IT team
- Update email filtering rules if phishing bypassed existing controls
- Update detection rules in Microsoft Defender or SIEM if applicable
- Schedule phishing simulation for staff awareness if click rate exceeded 10%
- Update this playbook if gaps were identified

13. Framework Alignment

NIST Cybersecurity Framework (CSF)

Control ID	Control Name	Playbook Application
DE.CM-4	Malicious code detection	Endpoint and email scanning for malicious attachments and URLs

Control ID	Control Name	Playbook Application
DE.AE-2	Event analysis	Log review, sign-in analysis, and alert triage steps
RS.RP-1	Response plan execution	This playbook constitutes the documented response plan
RS.MI-1	Incident containment	Containment actions per severity level (Sections 7-8)
RS.AN-1	Detection investigation	Investigation steps and log review (Section 6)
RC.IM-1	Recovery improvement	Post-incident actions and lessons learned (Section 12)

HIPAA Security Rule Alignment

45 CFR 164.308(a)(1)	Security Management Process — Risk Analysis and Risk Management
45 CFR 164.308(a)(5)	Security Awareness and Training — including phishing awareness
45 CFR 164.308(a)(6)	Security Incident Procedures — response and reporting
45 CFR 164.312(b)	Audit Controls — logging and monitoring requirements
45 CFR 164.400	Breach Notification Rule — patient notification obligations

ISO/IEC 27001:2022 Alignment

This playbook supports the following ISO/IEC 27001:2022 Annex A controls and clauses:

ISO 27001 Control	Control Name	Application
A.5.24	Information security incident management planning	Documented structured incident response procedures
A.5.25	Assessment and decision on information security events	Severity classification and triage (Section 4 and 6)
A.5.26	Response to information security incidents	Containment, eradication and recovery actions (Sections 7-9)
A.5.27	Learning from information security incidents	Post-incident actions and lessons learned (Section 12)
A.5.28	Collection of evidence	Evidence collection and chain-of-custody (Section 11)
A.6.8	Information security event reporting	Trigger conditions and user reporting procedures (Section 3)
A.8.16	Monitoring activities	Log and alert review steps in investigation (Step 3)